

Automating Wazuh Active Response to Disable Unauthorized New User Accounts

In the lesson will detect any unauthorized or suspicious local user account created on our WAZUH agent or Windows agent and system.

Understanding How to check the detection flow

The WAZUH Windows agent will generate the log whenever someone creates a user. The WAZUH manager will detect the rules and match it with its local rule. An alert will be generated. The active response will be triggered, and the user account or suspicious account will be disabled.

We can describe it with this diagram:

Windows Agent → Windows Security Event (User Creation) → Wazuh Manager (Rule Match) → Alert Generate → Active Response Trigger → Suspicious Local User Disabled

In Windows, the event ID for user account creation is 4720.

NB: Basically, it is a security event that creates a user account

The risk: it is used for persistence.

Field	Event ID	Log Name	Meaning	Risk
Detail	4720	Security	A user account was created	Possible persistence

Step 1: configure audit computer account management and audit user account management

We will go to our Windows agent or WAZUH agent and do:

type **local security policy** and click on it. Here, we will configure the audit policy (**Advanced Audit Policy Configuration**), so click on it and click on **System Audit Policies-Local Group Object**. Here, we will go to **account management** and configure:

- **audit computer account management**.
- **audit user account management**.

After that, go to PowerShell. Right-click and run as administrator, then forcefully update the group policy we just configured (**gpupdate /force**). And enter. The group policy will be updated.

Step 2: create a detection rule on our WAZUH server

Detection rule on our WAZUH server will detect unauthorized user creation.

Do, open the file **local_rule.xml** in this path **/var/ossec/etc/rules**. (sudo cd /var/ossec/etc/rules), go to the end of that local rules file and paste thus detection rule code:

```
<group name="windows,account management, unauthorized_user;">
<rule id="100500" level="12">
<if_sid>60103</if_sid>
<field name="win.system.eventID">4720</field>
<description>
```

```

ALERT: Unauthorized local user account: ** $(win.eventdata.targetUserName) ** created - Verify if authorized
</description>
<mitre>T1136</mitre>
<options>no_full_log</options>
</rule>
</group>

<group name="windows,account_management,account_disabled,">
<rule id="100501" level="10">
<if_sid>60103</if_sid>
<field name="win.system.eventID">4725</field>

<description>
INFO: Wazuh Auto-Response disabled account: ** $(win.eventdata.targetUserName)
</description>
<mitre>T1531</mitre>
<options>no_full_log</options>
</rule>
</group>

```

This configuration block has the ID 100500. Here, when event 4720 (account creation) is generated, an alert will be triggered (code block 1). And on configuration code or block 2, the account 4725 we will disable is mentioned.

Save the file.

After that, go to our WAZUH server and check if the configuration we applied for is working or not.

Run the command:

- `sudo /var/ossec/bin/wazuh-analysisd -t`

Hit enter.

```

2026/04/04 20:35:28 wazuh-analysisd: WARNING: Empty Mitre information for rule '100500'
2026/04/04 20:35:28 wazuh-analysisd: WARNING: Empty Mitre information for rule '100501'

```

this is telling us that it's empty, which is fine.

- **NB:** If there were any critical errors in our configuration block, it would have shown it to us here. We can go back to local rules and delete one thing (example remove > on this </group>) and save it. Go to the WAZUH server. And run this command: `sudo /var/ossec/bin/wazuh-analysisd -t` it will generate this critical error for us:

```

2026/04/04 20:36:31 wazuh-analysisd: ERROR: (1226): Error reading XML file 'etc/rules/local_rules.xml': XMLERR: End of file and some elements were not closed. (line 155).
2026/04/04 20:36:31 wazuh-analysisd: CRITICAL: (1220): Error loading the rules: 'etc/rules/local_rules.xml'.

```

This shows us we have created the detection rule.

Step 3: Create an active response on Windows agent

This active response script will disable the user.

Do, go into our agent's configuration file, active response, (C:\Program Files (x86)\ossec-agent\active-response) and there we will create a .bat file.

NB: It's not letting us create the folder.

Go to downloads and create the file with `.bat` extension (user_account.bat) and past this code:

```
@echo off
Set username=%1
Net user %username% /active:no
save this file.
```

Go to your Wazuh dashboard and call the active response script you created from the server side. (menu→Agents management→ groups and open agent.conf for windows group) and at the end of our centralized configuration file, I will call my active response. We have added this configuration block or configuration paste this code block:

```
<!-- Active response configuration - Disable User Creation -->
<active-response>
  <command>disable-user</command>
  <location>local</location>
  <rules_id>100500</rules_id>
  <rules_id>100501</rules_id>
</active-response>

<command>
  <name>disable-user</name>
  <executable>disable_user.bat</executable>
  <timeout_allowed>no</timeout_allowed>
</command>
```

NB: This will call the rules we created.

When these rules are triggered, the script we made will be executed

```
<executable>disable_user.bat</executable>
```

Save. And our file will successfully be edited.

Go on Wazuh server and check our configuration again by running this command:

```
- sudo /var/ossec/bin/wazuh-analysisd -t
```

```
2026/04/04 20:35:28 wazuh-analysisd: WARNING: Empty Mitre information for rule '100500'
2026/04/04 20:35:28 wazuh-analysisd: WARNING: Empty Mitre information for rule '100501'
```

All good, restart your Wazuh server.

Step 4: create the user account and see the effect on wazuh dashboard

Go back to your Windows agent and create a user account by running this command on PowerShell as administrator: `net user hacker123 p@ssword /add`

By checking it on Wazuh dashboard we can see that the alert has been generated showing that the user account has been created

A screenshot of the Wazuh dashboard showing an alert. The alert is titled "ALERT: Unauthorized local user account: ** hacker123 ** created - Verify if authorized". It includes a red progress bar and a status of "100500".

and as soon as the user is disabled, the second alert will be generated.

A screenshot of the Wazuh dashboard showing an alert. The alert is titled "INFO: Wazuh Auto-Response disabled account: ** hacker123". It includes a red progress bar and a status of "100501".

We have received the second alert as well (INFO), Wazuh auto response has disabled this user.

We can also verify this on our Wazuh agent or Windows agent as well by executing this script:

- `Get-LocalUser | Select-Object Name, Enabled` (run PowerShell as admin) to see this:

```
PS C:\Windows\system32> Get-LocalUser | Select-Object Name, Enabled

Name                Enabled
-----
Administrator       False
DefaultAccount      False
Guest                False
hacker123            False
Usman                True
WDAGUtilityAccount  False
```

We can see that our user hacker123 is not enabled. It has been disabled. If you still want to check it, type this command:

- `control userpasswords2`

this



Will pop-up

After that, we will go to advanced→Advanced→ users→hacker123 and look. We will see that the account has been disabled. So, our auto response has disabled the unauthorized user.



Automating Wazuh Active Response to Disable Unauthorized New User Accounts

Step-by-step guide to detect, alert and automatically disable suspicious local user accounts



- Detect
- Respond
- Protect

1 Overview and Detection Flow

What we will do

Detect any unauthorized or suspicious local user account created on our Wazuh agent or Windows system, and automatically disable it using active response.

Detection Flow



✓ Windows Event ID 4720 = A user account was created.

⚠ Risk: It can be used for persistence by attackers.

Field	Event ID	Log Name	Meaning	Risk
Detail	4720	Security	A user account was created	Possible persistence

2 Configure Audit Policy on Windows

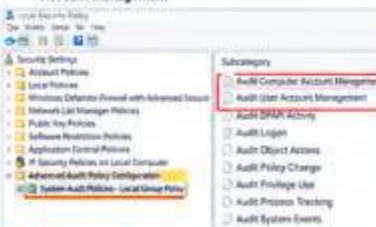
1 Open Local Security Policy

Press Win + R, type **local security policy** and click OK.



2 Navigate to Audit Policy

Go to: **Advanced Audit Policy Configuration** → **System Audit Policies** → **Local Group Policy** → **Account Management**



3 Enable the two policies

Double-click each policy and select:

✓ Success

✓ Failure



4 Update Group Policy

Open PowerShell as Administrator and run:

```
PS C:\Windows\system32> gpupdate /force
Updating policy...
Computer Policy update has completed successfully.
```

5 Configure Active Response in Wazuh

1 Open the agent configuration (Windows group)

In the Wazuh dashboard:
Go to **Agents management** → **Groups** → **open agent.conf** for your Windows group and add this:

```
<!-- Active response configuration - Disable User Creation -->
<active-response>
  <command>disable-user</command>
  <location>local</location>
  <rules_id>100500</rules_id>
  <rules_id>100501</rules_id>
</active-response>

<command>
  <name>disable-user</name>
  <executable>disable_user.bat</executable>
  <timeout_allowed>no</timeout_allowed>
</command>
```

2 Save the configuration

Save the file. This will call the rules we created when triggered.



3 Create a Detection Rule on Wazuh

1 Open the local_rules.xml file

On your Wazuh server, go to **/var/ossec/etc/rules** and edit the file:

```
user@wazuh:~$ sudo cd /var/ossec/etc/rules
user@wazuh:/var/ossec/etc/rules$ sudo nano local_rules.xml
```

2 Add the detection rule for user creation (Event 4720)

Paste this code at the end of the file:

```
<group name="windows,account_management,
unauthorized_user,">
  <rule id="100500" level="12">
    <if_sid>60103</if_sid>
    <field name="win.system.eventid">4720</field>
    <description>
      ALERT: Unauthorized local user account:
      $(win.eventdata.targetUsername) created -
      Verify if authorized
    </description>
    <mitre>T1136</mitre>
    <options>no_full_log</options>
  </rule>
</group>
```

3 Add the rule for account disabled (Event 4725)

Paste this code:

```
<group name="windows,account_management,
account_disabled,">
  <rule id="100501" level="10">
    <if_sid>60103</if_sid>
    <field name="win.system.eventid">4725</field>
    <description>
      INFO: Wazuh Auto-Response disabled account:
      $(win.eventdata.targetUsername)
    </description>
    <mitre>T1133</mitre>
    <options>no_full_log</options>
  </rule>
</group>
```

4 Save and test the configuration

Run the command to check for errors:

```
user@wazuh:~$ sudo /var/ossec/bin/wazuh-analysisd -t
```

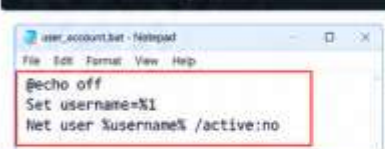
✓ If no critical errors, the configuration is correct.

4 Create the Active Response Script

1 Create the .bat file on Windows agent

Go to Downloads, create a file named **user_account.bat** and add this code:

```
@echo off
Set username=%1
Net user %username% /active:no
```



2 Save the file

Save it as: **user_account.bat**

Example location: **C:\Users\YourName\Downloads**



Then copy/move this file to the agent's active response folder when needed:
C:\Program Files (x86)\ossec-agent\active-response

6 Test the Active Response

1 Create a test user on Windows agent

Open PowerShell as Administrator and run:

```
PS C:\Windows\system32> net user hacker123 p@ssw0rd /add
The command completed successfully.
```

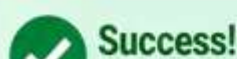
2 Check alerts in Wazuh dashboard

Go to **Security events** and search for the alert:



3 Verify the user is disabled

A second alert (Event 4725) will be generated:



Success!

You have now automated Wazuh to detect and disable unauthorized new user accounts on your Windows agents.



Key Takeaways

- Event ID 4720 = user created (detect)
- Event ID 4725 = user disabled (confirm)
- Wazuh + Active Response = automatic mitigation
- Helps prevent persistence and unauthorized access



Next Steps

- Test with different scenarios
- Monitor alerts regularly
- Tune rules to reduce false positives
- Extend to other active response actions